

Encuesta SQUARE de Requisitos de Seguridad

Modelo integral para organizaciones en España (marco SQUARE + NIS2 + Estrategia Nacional)

Versión 1.0 – Borrador para uso en pilotos sectoriales

Este cuestionario no pretende juzgarle; solo poner números a lo que usted ya sospecha.

0. Datos básicos de la organización

P0.1. Sector principal de actividad (seleccione el que mejor encaje):

- Operador esencial NIS2 (energía, transporte, banca, salud, agua, infraestructuras digitales, etc.)
- Operador importante NIS2
- Administración pública (AGE, CCAA, EELL)
- Proveedor TIC/OT para operadores esenciales/importantes
- Otra organización privada con alta dependencia digital
- Prefiero no responder, pero quiero seguir con la encuesta

P0.2. Tamaño aproximado de la organización (empleados):

- < 50
- 50–249
- 250–999
- 1 000–4 999
- ≥ 5 000
- No se dispone de este dato de forma consolidada

P0.3. Ámbito geográfico principal de operación:

- Local / provincial
- Autonómico
- Nacional
- Europa (incluida España)
- Global
- No aplica / no se desea indicar

P0.4. Rol de la persona que responde (marca todas las que apliquen):

- CISO / Responsable de Seguridad de la Información
- CIO / CTO / Dirección de Tecnología
- Responsable de Continuidad de Negocio
- Responsable de Cumplimiento / Riesgos
- Responsable de Desarrollo / Ingeniería de Software
- Otro (especificar brevemente en texto libre)

P0.5. ¿Sobre cuántos sistemas “críticos” piensa usted al responder este cuestionario?

- 1 sistema específico
- 2–5 sistemas
- 6–10 sistemas
- > 10 sistemas
- No hay una definición consensuada de “sistema crítico” en mi organización

1. Gobernanza y proceso SQUARE-like

P1.1. ¿Existe en su organización un proceso formal de ingeniería de requisitos de seguridad inspirado en SQUARE u otra metodología similar?

- Sí, explícitamente basado en SQUARE (documentado y vigente)
- Sí, basado en otra metodología formal (por ejemplo, ISO/IEC, NIST, propia)
- Se realiza de facto un proceso de requisitos de seguridad, pero no está formalizado
- Depende del proyecto y del proveedor
- No existe un proceso identificable
- No lo sé / no aplica

P1.2. La definición de objetivos de seguridad para proyectos críticos (equivalente al “acuerdo sobre objetivos” de SQUARE) se realiza normalmente...

- Siempre antes del diseño técnico
- Casi siempre antes del diseño técnico
- A veces se hace, a veces no
- Casi nunca, se asume que “seguridad” ya viene implícita
- Nunca de forma explícita
- No lo sé

P1.3. La organización dispone de un glosario corporativo de términos de seguridad y riesgo (similar al paso de “definición de términos” de SQUARE):

- Sí, centralizado, mantenido y difundido
- Sí, pero fragmentado por áreas/equipos
- Hay intentos, pero no está actualizado
- No existe, cada uno interpreta “riesgo” y “crítico” a su manera
- No lo sé

P1.4. ¿Quién participa habitualmente en la identificación de requisitos de seguridad de sistemas críticos? (marque todas las que apliquen)

- Seguridad / CISO
- Desarrollo / Ingeniería
- Operaciones / Explotación
- Negocio / Propietarios de procesos
- Proveedores externos
- Jurídico / Cumplimiento

- Otros (especificar)
- No existe un proceso definido de participación

P1.5. En proyectos recientes, el proceso de requisitos de seguridad ha estado...

- Integrado en el ciclo de vida de desarrollo (DevSecOps o similar)
- Integrado parcialmente, en fases de análisis y diseño
- Tratado como paso previo a auditorías y certificaciones
- Mantenido como actividad reactiva tras incidentes
- Ausente o residual
- No aplica / no hay proyectos recientes

P1.6. ¿Se realiza alguna forma de auditoría o revisión interna del proceso de requisitos de seguridad (equivalente a una “inspección SQUARE”)?

- Sí, con revisiones formales y criterios definidos
- Sí, pero de forma irregular y basada en buena voluntad
- Solo cuando hay un incidente grave
- No, los documentos de requisitos rara vez se revisan en profundidad
- No lo sé

2. Identificación de activos y riesgos

P2.1. ¿Dispone la organización de un inventario actualizado de activos críticos de información y sistemas asociados?

- Sí, centralizado y actualizado al menos anualmente
- Sí, pero con diferencias importantes entre áreas
- Existe un inventario, pero no está actualizado
- No existe un inventario formal
- No lo sé

P2.2. Para cada activo crítico, ¿se documentan explícitamente las amenazas relevantes y su nivel de riesgo?

- Sí, para la mayoría de los activos críticos
- Sí, pero solo para ciertos activos “estrella”
- Se documentan amenazas de forma genérica, no por activo
- No se documentan amenazas de forma sistemática
- No lo sé

P2.3. En proyectos de desarrollo o adquisición de sistemas críticos, la organización utiliza técnicas estructuradas de análisis de amenazas (por ejemplo, STRIDE, attack trees, etc.):

- De forma sistemática, en todos los proyectos críticos
- De forma habitual, pero no siempre
- Ocasionalmente, en proyectos “importantes”
- Nunca o casi nunca
- No lo sé

P2.4. ¿Se relacionan explícitamente los riesgos identificados con los requisitos de seguridad que deben mitigarlos?

- Sí, existe una matriz riesgo-requisito para los sistemas críticos
- Sí, pero la matriz se queda en la documentación inicial y no se mantiene
- Solo se hace en proyectos con auditoría externa
- No, los requisitos no se trazan a riesgos de forma explícita
- No lo sé

P2.5. Nivel de formalización del apetito y tolerancia al riesgo de ciberseguridad a nivel corporativo:

- Definido y aprobado por el máximo órgano de gobierno
- Definido en alguna política, pero no aprobado al máximo nivel
- Existente de facto, pero no documentado
- No se ha discutido a ese nivel
- No lo sé

3. Cobertura y calidad de los requisitos de seguridad

P3.1. Para sistemas críticos, ¿qué proporción aproximada de funcionalidades de negocio dispone de requisitos de seguridad explícitos y documentados?

- > 90 %
- 70–90 %
- 40–69 %
- 10–39 %
- < 10 %
- No lo sabemos / no se mide

P3.2. ¿Se distingue entre requisitos de seguridad esenciales, condicionales y opcionales (o categorización equivalente de criticidad)?

- Sí, con criterios claros y homogéneos
- Sí, pero los criterios varían por proyecto
- Se usan términos similares, pero sin criterios claros
- No se hace esa distinción
- No lo sé

P3.3. ¿Con qué frecuencia los requisitos de seguridad son rechazados o devueltos por ser ambiguos, no verificables o poco realistas?

- Casi nunca (≤ 10 %)
- Ocasionalmente (10–30 %)
- Con frecuencia (30–60 %)
- Casi siempre (> 60 %)
- No se revisan con ese nivel de exigencia
- No lo sé

P3.4. Para los requisitos de seguridad definidos, ¿se especifica sistemáticamente el método de verificación asociado (pruebas, revisión, auditoría, monitorización continua, etc.)?

- Sí, en la mayoría de los requisitos
- Sí, pero solo en proyectos regulados o certificados
- A veces, cuando alguien se acuerda
- Raramente
- No lo sé

P3.5. ¿Se mantiene trazabilidad desde los requisitos de seguridad hasta los controles implementados (por ejemplo, políticas, configuraciones, medidas técnicas)?

- Sí, en un repositorio o herramienta de requisitos
- Sí, pero de forma parcial y distribuida en documentos
- Solo para ciertos proyectos o certificaciones
- No, la trazabilidad se pierde tras el diseño inicial
- No lo sé

P3.6. En su opinión, la calidad media de los requisitos de seguridad documentados en su organización es...

- Alta: claros, medibles, alineados con el riesgo
- Aceptable: útiles pero irregulares
- Mejorable: muchos son genéricos o vagos
- Baja: abundan las frases tipo “garantizar la máxima seguridad posible”
- No se dispone de suficientes evidencias para opinar

4. Métricas, indicadores y seguimiento

P4.1. ¿Dispone la organización de métricas específicas sobre requisitos de seguridad (por ejemplo, cobertura, calidad, reusabilidad)?

- Sí, con indicadores definidos y revisados periódicamente
- Sí, pero se usan de forma irregular
- Existen métricas ad hoc en algunos proyectos
- No hay métricas específicas de requisitos de seguridad
- No lo sé

P4.2. ¿Se realiza algún tipo de cuadro de mando que conecte requisitos de seguridad con indicadores de incidentes, vulnerabilidades u otros resultados?

- Sí, de manera sistemática
- Sí, pero solo para ciertos sistemas o campañas
- En ocasiones, mediante análisis puntuales
- No, los requisitos viven en un universo paralelo al de los incidentes
- No lo sé

P4.3. Indique qué tipos de indicadores utiliza su organización (marque todos los que apliquen):

- Número de requisitos de seguridad por sistema crítico
- Porcentaje de funcionalidades críticas con requisitos de seguridad
- Porcentaje de requisitos revisados sin observaciones
- Tiempo medio desde identificación de riesgo hasta definición de requisito
- Relación entre incidentes de cierto tipo y requisitos asociados
- Otros (describa brevemente)
- Ninguno de los anteriores / no se utilizan indicadores

P4.4. Frecuencia con la que se revisan y actualizan los requisitos de seguridad en sistemas críticos:

- Al menos una vez al año
- Coincidiendo con cambios significativos del sistema
- Solo tras incidentes relevantes
- Esporádicamente, sin patrón
- Prácticamente nunca
- No lo sé

P4.5. ¿Se dispone de una estimación del coste asociado al ciclo de vida de requisitos de seguridad (definición, revisión, pruebas, mantenimiento)?

- Sí, cuantificado y asignado en presupuestos
- Sí, pero estimado a ojo de buen cubero
- Solo conocemos el coste cuando “estalla” un proyecto
- No, es un coste invisible
- No lo sé

5. Cumplimiento normativo y alineamiento con marcos (NIS2, ENS, etc.)

P5.1. ¿En qué medida considera que su proceso de requisitos de seguridad está alineado con las obligaciones de NIS2 (o normativas sectoriales equivalentes)?

- Altamente alineado y revisado por expertos legales / de cumplimiento
- Razonablemente alineado, aunque no formalizado en detalle
- Parcialmente alineado, con lagunas evidentes
- Poco alineado; se trabaja más por controles que por requisitos
- No lo sé / no aplica

P5.2. En el caso de la Administración pública o proveedores a AA.PP., ¿cómo se integra el Esquema Nacional de Seguridad (ENS) en el proceso de requisitos?

- ENS está sistemáticamente mapeado a requisitos de sistemas críticos
- ENS se tiene en cuenta, pero de forma manual y no estructurada
- ENS se aplica solo en fases de auditoría/certificación
- ENS se percibe como un documento externo, no como motor de requisitos
- No aplica / no lo sé

P5.3. ¿Se han utilizado guías o marcos de ENISA para orientar la definición de requisitos de seguridad o la construcción de métricas?

- Sí, en proyectos concretos
- Sí, de manera transversal
- Se conocen, pero no se usan realmente
- No se conocen en la práctica
- No lo sé

P5.4. Para estándares específicos (ISO 27001, ISO 27701, etc.), la relación entre controles y requisitos de seguridad se encuentra...

- Claramente documentada en matrices de correspondencia
- Parcialmente documentada en ciertos proyectos
- No documentada, pero se asume que “están alineados”
- No existe tal relación en la práctica
- No lo sé / no aplica

6. Integración con la continuidad de negocio y resiliencia

P6.1. ¿Se consideran de forma explícita requisitos de seguridad relativos a continuidad y resiliencia (RTO, RPO, degradación graciosa, etc.) en la fase de requisitos?

- Sí, de manera sistemática y cuantificada
- Sí, pero con predominio de términos cualitativos (“rápido”, “aceptable”)
- Solo cuando lo exige una normativa o cliente
- Raramente
- No lo sé

P6.2. En los ejercicios de continuidad de negocio / ciber-ejercicios, ¿se validan indirectamente los requisitos de seguridad definidos?

- Sí, se comprueba si los requisitos se sostienen bajo estrés
- Sí, pero sin trazabilidad explícita a los requisitos
- A veces, de forma intuitiva
- Raramente o nunca
- No lo sé

P6.3. ¿Se revisan los requisitos de seguridad tras un incidente grave o un ejercicio de crisis?

- Siempre, con lecciones aprendidas formalizadas
- Casi siempre, según la gravedad
- A veces, pero sin método
- Casi nunca
- No lo sé

7. Tecnología, herramientas y capacidades

P7.1. ¿Utiliza la organización herramientas específicas para gestionar requisitos (ALM, RM, etc.) que incluyan requisitos de seguridad?

- Sí, herramientas corporativas integradas con el ciclo de vida
- Sí, pero distintas por área/proyecto
- Herramientas ofimáticas genéricas (documentos, hojas de cálculo, etc.)
- No se utilizan herramientas específicas
- No lo sé

P7.2. Nivel medio de capacitación del personal clave en ingeniería de requisitos de seguridad (SQUARE, u otras metodologías):

- Alto: formación específica y experiencia contrastada
- Moderado: formación parcial y experiencia en algunos proyectos
- Bajo: conocimientos dispersos y autodidactas
- Muy bajo: la ingeniería de requisitos se ve como un lujo teórico
- No lo sé

P7.3. ¿Se dispone de pautas o plantillas estándar para requisitos de seguridad reutilizables entre proyectos?

- Sí, un catálogo oficial de requisitos de seguridad tipo
- Sí, repositorios informales reusados por afinidad
- Se “copia y pega” de proyectos anteriores sin mucho control
- No existen plantillas ni catálogos
- No lo sé

8. Perspectiva económica: IGM (Índice de Gestión de Mandato) y ROI

P8.1. ¿Se calcula algún tipo de retorno de inversión (ROI) o beneficio estimado de las actividades de requisitos de seguridad?

- Sí, con modelos económicos internos
- Sí, pero de forma muy aproximada
- A veces, en proyectos de alto presupuesto
- Nunca, se considera coste hundido
- No lo sé

P8.2. La dirección percibe la definición temprana de requisitos de seguridad como...

- Una inversión estratégica que ahorra costes posteriores
- Un mal necesario, pero asumible
- Un lastre que retrasa proyectos
- Un territorio brumoso que prefiere no mirar
- No se ha planteado explícitamente

P8.3. ¿Dispone de algún indicador que refleje el “grado de cumplimiento” de los mandatos internos o regulatorios en materia de requisitos de seguridad (Índice de Gestión de Mandato – IGM)?

- Sí, uno o varios indicadores formales
- Se está trabajando en ello

- No, pero nos gustaría disponer de uno
- No, y no está en la agenda
- No lo sé

9. Futuro, cultura y autocrítica constructiva

P9.1. ¿Qué barreras principales encuentra su organización para mejorar la ingeniería de requisitos de seguridad? (marque hasta tres)

- Falta de tiempo
- Falta de personal cualificado
- Falta de apoyo de la alta dirección
- Falta de herramientas adecuadas
- Falta de claridad regulatoria
- Cultura de “apagar fuegos” en lugar de diseñar bien
- Otras (especificar brevemente)

P9.2. Si dispusiera de presupuesto y apoyo político suficientes, ¿qué mejora priorizaría en su proceso de requisitos de seguridad?

- Formación especializada (SQUARE, ingeniería de requisitos)
- Herramientas y automatización
- Refuerzo de equipo y roles
- Normalización de plantillas y catálogos de requisitos
- Integración con métricas, cuadros de mando y ROI
- Otros (especificar)

P9.3. En una escala del 1 al 5, donde 1 es “vivimos en el lejano oeste digital” y 5 es “somos un monasterio cartujo de disciplina cibernética”, ¿cómo valoraría el estado actual de sus requisitos de seguridad?

- 1 – Lejano oeste digital
- 2 – Hay sheriff, pero pocos alguaciles
- 3 – Nos defendemos con dignidad
- 4 – Bastante orden, con algún que otro motín
- 5 – Monasterio cartujo de disciplina cibernética
- Prefiero no contestar, por pudor profesional

P9.4. Campo abierto para observaciones adicionales, confesiones o súplicas al oráculo SQUARE:

Respuesta en texto libre